PLATFORM DESIGN · RBAC BEST PRACTICES

Role Hierarchy & Access Control Guide

Who sees what, who can do what, and why — across every level of the Sovereign Knowledge Platform. Based on industry standards from Confluence, Notion, and leading RAG platforms.

The guiding principle

Every enterprise knowledge platform that scales successfully follows one rule: **users should only ever see the level of the system that they own and operate.** A workspace member should never see organization billing. An org admin should never see other organizations. This creates trust, reduces cognitive overload, and prevents accidental data exposure — which in a RAG system is a critical security boundary, not just a UX preference.

The hierarchy you're building mirrors exactly what Confluence, Notion Enterprise, and Guru use — a **three-tier model**: Platform → Organization → Workspace. Each tier has its own admin, and admins at each tier cannot escalate their access upward.

🔒 **Security principle (from OWASP and Pinecone):** In RAG systems, access control must be enforced at retrieval time — not just in the UI. Even if a user navigates to a URL they shouldn't access, the backend query must filter to only documents their role permits. UI hiding is the first layer; query-time filtering is the security layer.

The 5-role hierarchy

👑 **Platform Owner**

God mode · All orgs · All settings

🏛 **Org Admin**

One organization · All its workspaces · No platform

📂 **Workspace Admin**

Assigned workspaces only · No org or platform

📝 **Workspace Editor / Contributor**

Can upload docs, manage connectors in their workspace

💬 **Member (Read-Only / Chat User)**

Can only ask questions and read answers · No management

Role-by-role breakdown

👑

Platform Owner

Tier 0

You — the SaaS operator

The person or team running the platform itself. Can see everything, go anywhere, and manage any organization — but should rarely need to touch individual workspace content.

✦ PLATFORM-LEVEL ACCESS

- ✓ View Platform Overview with all-org metrics
- ✓ Create, suspend, and archive organizations
- ✓ Impersonate any org for support (with audit log)
- ✓ View all billing, invoices, usage across orgs
- ✓ Manage platform settings (LLM config, GPU routing, storage)
- ✓ Access full audit log across all organizations

🏛

Org Admin

Tier 1

The client's IT lead or account owner

Owns one organization. Sees everything within their org — all workspaces, billing, team members, analytics. Cannot see other organizations or platform-level configuration. Cannot delete the organization (only Platform Owner can).

✦ WHAT THEY CAN DO

- ✓ View org dashboard with all-workspace rollup metrics
- ✓ Create, rename, and archive workspaces within their org
- ✓ Invite users to the org, assign roles (up to Workspace Admin)

- ✓ Set platform-wide feature flags and limits
- ✓ Assign Org Admin role to users

✦ ORG & WORKSPACE ACCESS

- ✓ Navigate into any org or workspace
- ✓ Read (not edit) any workspace's documents and chats
- ✓ View connector sync status for any org
- ✗ Should NOT routinely access individual org chats (audit this)

✦ WHAT THEY SEE IN THE SIDEBAR

- ✓ Platform Overview, Organizations list
- ✓ All menu items: Workspaces, Chats, Team, Analytics, Documents, Connectors, Billing, Audit Log, Settings

- ✓ Remove users from the org
- ✓ Manage org-level billing, upgrade/downgrade plans
- ✓ View org-level audit log (queries, logins, admin actions)
- ✓ Configure org SSO settings
- ✓ Manage all connectors across all workspaces
- ✓ Access analytics across all org workspaces
- ✓ View all chats in all workspaces (for support/compliance)

✦ WHAT THEY CANNOT DO

- ✗ Delete the organization (Platform Owner only)
- ✗ See other organizations on the platform
- ✗ Access Platform Overview or platform settings
- ✗ Assign Platform Owner role to anyone
- ✗ Access platform-level billing or infrastructure settings

✦ SIDEBAR VIEW

- ✓ Dashboard, Workspaces, Chats
- ✓ Team, Analytics, Documents, Connectors
- ✓ Billing, Audit Log, Settings
- ✗ No Platform Overview, No Organizations list

Workspace Admin

Tier 2

Team lead, department head

Manages one or more assigned workspaces. Has full control within those workspaces — documents, connectors, members — but cannot see org-level data, billing, or other workspaces they're not assigned to.

✦ WHAT THEY CAN DO

- ✓ Create and delete workspaces (within their org scope)
- ✓ Manage documents: upload, re-index, delete in their workspace
- ✓ Manage connectors: connect, disconnect, trigger sync
- ✓ Invite and remove members from their workspace(s)

Editor / Contributor

Tier 3

Knowledge manager, content owner

A power user who can contribute to the knowledge base but has no administrative responsibility. Think: the person responsible for keeping documents up to date. Can upload and manage documents but cannot change settings or manage users.

✦ WHAT THEY CAN DO

- ✓ Upload documents and files
- ✓ Delete documents they uploaded
- ✓ Trigger manual re-index of documents
- ✓ View connector sync status (read-only)
- ✓ Use chat to query the knowledge base

- ✓ View workspace-level analytics (queries, confidence trends)
- ✓ View workspace-level audit log
- ✓ Configure workspace AI settings (model, confidence threshold)
- ✓ View all chats within their workspace

✦ WHAT THEY CANNOT DO

- ✗ See org-level dashboard, billing, or team roster
- ✗ See workspaces they're not assigned to
- ✗ Assign Org Admin role to anyone
- ✗ Access org-level audit log or SSO settings
- ✗ Delete the organization or invite org-level users

✦ SIDEBAR VIEW

- ✓ Workspace selector (only assigned workspaces)
- ✓ Chats, Documents, Connectors, Analytics (workspace-scoped)
- ✓ Team (workspace members only)
- ✓ Workspace Settings
- ✗ No Dashboard, No Billing, No Org Audit Log, No Platform

- ✓ View their own chat history
- ✓ See basic workspace analytics (their own queries)
- ✓ Flag answers as incorrect or suggest improvements

✦ WHAT THEY CANNOT DO

- ✗ Connect or disconnect integrations
- ✗ Invite or remove users
- ✗ Change workspace settings
- ✗ View other users' chat history
- ✗ See org or platform level anything

✦ SIDEBAR VIEW

- ✓ Chat (their workspace only)
- ✓ Documents (upload/manage)
- ◐ Connectors (read-only — can see sync status)
- ✗ No Team, No Analytics, No Billing, No Audit Log, No Settings

Member (Chat User)

Tier 4

End user — the whole point of the product

The majority of your users. They open the app, ask questions, get cited answers, and go back to work. That's it. The entire product exists to serve this person. Their experience should be frictionless — no admin noise, no management UI, just a clean chat interface.

✦ WHAT THEY CAN DO

- ✓ Use chat to query their assigned workspace(s)
- ✓ View their own conversation history
- ✓ Thumbs up/down on answers (feedback)
- ✓ Export their own chat answers to PDF
- ✓ View their profile and notification settings

✦ WHAT THEY CANNOT DO

- ✗ Upload or delete documents
- ✗ See other users' chats
- ✗ Access connectors, analytics, audit log
- ✗ Invite users or manage the team
- ✗ See documents outside their workspace scope
- ✗ Access org or platform level anything

✦ SIDEBAR VIEW

- ✓ Chat only — clean, full-screen interface
- ✓ Conversation history (their own)
- ✓ Profile / account settings

What each role sees in the sidebar

Each role sees a completely different navigation. Members should land directly in chat — no sidebar complexity. As roles gain responsibility, the sidebar grows. This is the same pattern Notion, Confluence, and Linear all use.

Platform Owner

PLATFORM
- Overview
- Organizations

CORE APP
- Dashboard
- Workspaces
- Chats

KNOWLEDGE
- Team
- Analytics
- Documents
- Connectors

ENTERPRISE
- Billing
- Audit Log
- Settings

FULL ACCESS — ALL TIERS

Org Admin

PLATFORM
- ~~Overview~~
- ~~Organizations~~

CORE APP
- Dashboard
- Workspaces
- Chats

KNOWLEDGE
- Team
- Analytics
- Documents
- Connectors

ENTERPRISE
- Billing
- Audit Log
- Settings

ORG SCOPE — NO PLATFORM

Workspace Admin

PLATFORM
- ~~Overview~~

CORE APP
- ~~Dashboard~~
- My Workspaces
- Chats

WORKSPACE

Editor

WORKSPACE
- Chat
- Documents
- Connectors ◐

ACCOUNT
- Profile

HIDDEN

Team

Analytics

Documents

Connectors

ENTERPRISE

~~Billing~~

WS Audit Log

WS Settings

WORKSPACE SCOPE ONLY

~~Team~~

~~Analytics~~

~~Billing~~

~~Audit Log~~

~~Settings~~

CONTENT MGMT ONLY

Member

CHAT

New conversation

HISTORY

Today

Yesterday

Last week

ACCOUNT

Profile

CHAT ONLY — CLEAN UX

Complete permission matrix

Read across any row to see which roles can perform that action. This is the source of truth for your engineering team implementing route guards and API middleware.

ACTION / FEATURE	PLATFORM OWNER	ORG ADMIN	WORKSPACE ADMIN	EDITOR
PLATFORM MANAGEMENT				

ACTION / FEATURE	PLATFORM OWNER	ORG ADMIN	WORKSPACE ADMIN	EDITOR
View Platform Overview page	✓	✗	✗	✗
View all organizations list	✓	✗	✗	✗
Create new organization	✓	✗	✗	✗
Delete / archive organization	✓	✗	✗	✗
Suspend organization	✓	✗	✗	✗
Manage LLM / GPU configuration	✓	✗	✗	✗
View platform-wide audit log	✓	✗	✗	✗
Platform billing and invoices	✓	✗	✗	✗
Set platform-wide feature flags	✓	✗	✗	✗
Impersonate org (support mode)	✓	✗	✗	✗
ORGANIZATION MANAGEMENT				
View org dashboard	✓	✓	✗	✗
Create workspace in org	✓	✓	✗	✗
Delete workspace	✓	✓	✗	✗
Invite user to org	✓	✓	✗	✗
Remove user from org	✓	✓	✗	✗
Assign roles up to Workspace Admin	✓	✓	✗	✗
View org billing & usage	✓	✓	✗	✗
Configure org SSO settings	✓	✓	✗	✗
View org-level audit log	✓	✓	✗	✗

ACTION / FEATURE	PLATFORM OWNER	ORG ADMIN	WORKSPACE ADMIN	EDITOR
View org-wide analytics	✓	✓	✗	✗
WORKSPACE MANAGEMENT				
Access assigned workspaces	✓	✓	✓	✓
Rename workspace	✓	✓	✓	✗
Invite member to workspace	✓	✓	✓	✗
Remove member from workspace	✓	✓	✓	✗
Configure workspace AI settings	✓	✓	✓	✗
View workspace analytics	✓	✓	✓	✗
View workspace audit log	✓	✓	✓	✗
View all chats in workspace	✓	✓	✓	✗
DOCUMENT & KNOWLEDGE MANAGEMENT				
Upload documents	✓	✓	✓	✓
Delete any document	✓	✓	✓	Own only
Trigger re-index	✓	✓	✓	✓
View document list	✓	✓	✓	✓
View connector sync status	✓	✓	✓	Read-only
Connect / disconnect integrations	✓	✓	✓	✗
Configure connector settings	✓	✓	✓	✗
Trigger manual sync	✓	✓	✓	✗
CHAT & QUERY				
Ask questions / use chat	✓	✓	✓	✓

ACTION / FEATURE	PLATFORM OWNER	ORG ADMIN	WORKSPACE ADMIN	EDITOR	
View own conversation history	✓	✓	✓	✓	
View all users' conversations	✓	✓	✓	✗	
Flag/thumbs answer as incorrect	✓	✓	✓	✓	
Export chat to PDF	✓	✓	✓	✓	
Share conversation link	✓	✓	✓	✓	Wor

Critical security and UX rules

🔒 **Never show locked nav items — hide them entirely.** Showing a grayed-out "Billing" link to a Workspace Admin is confusing and feels like a broken product. Hide sections the user has no access to. Only reveal what they can interact with. Notion, Linear, and Slack all follow this pattern.

🛡️ **Enforce permissions at the API layer, not just the UI.** A determined user can call API endpoints directly if you only hide links in the UI. Every API route must verify role and scope before returning data. This is especially critical in RAG — a query that returns documents from outside the user's workspace is a data breach, not a UX bug.

⚠️ **Workspace Admin cannot create workspaces — only Org Admin and above.** This is your hierarchy rule from the brief. Workspace Admin manages what they're given. Only Org Admin can create/delete workspaces. This prevents workspace sprawl and keeps the org structure under control.

⚠️ **Only Platform Owner can delete an organization.** Org Admins can self-serve everything except deletion. This is a standard SaaS safety pattern — irreversible destructive actions require the highest privilege level. Org Admins can archive/suspend, but not hard-delete.

💡 **Members should land directly in chat with zero admin chrome.** When a Member logs in, route them straight to the chat interface. No sidebar full of locked items. No "you don't have access" pages. Just a clean chat. This is the entire product from their perspective — protect that experience.

💡 **Queries must filter to the user's accessible document set.** A workspace member should never get an answer sourced from documents in another workspace. Enforce this at the vector search query level by passing the user's `workspace_id` and `user_id` as metadata filters — not just by hiding UI elements.

💡 **Audit log every admin action, not just queries.** Log: who created/deleted what, role changes, connector connects/disconnects, document uploads/deletions, and any impersonation by Platform Owner. Org Admins in compliance-heavy industries (GovCon, legal) will ask for this log during sales calls.

Implementation checklist for your dev team

01	**Define roles in your database** Create a `roles` enum: `platform_owner | org_admin | workspace_admin | editor | member`. Store user roles in an `org_members` table with `{user_id, org_id, role}` and a `workspace_members` table with `{user_id, workspace_id, role}`. A user can have different roles in different workspaces.
02	**Build a permission middleware for every API route** Every API endpoint needs a guard: `requireRole('org_admin', orgId)` or `requireWorkspaceAccess(workspaceId)`. The guard reads the user's JWT, fetches their role for the requested resource scope, and rejects with 403 if insufficient. Never trust the frontend to enforce access.
	Scope all vector search queries by workspace

03	When a user queries, pass their `workspace_id` as a metadata filter to pgvector/Pinecone. The query should be: `WHERE workspace_id = ? AND (user's accessible doc IDs)`. Never return documents from outside the user's scope, even if they're semantically relevant.
04	**Implement navigation guards in the frontend** On login, fetch the user's `effectiveRole` and `accessibleWorkspaces`. Use this to render only the nav items the user can access. Never render admin nav items with a disabled/locked state — simply don't render them. React Router's `PrivateRoute` or Next.js middleware handle this cleanly.
05	**Default landing route by role** Platform Owner → `/platform/overview`. Org Admin → `/dashboard`. Workspace Admin → `/workspaces/{first_ws}/chat`. Editor → `/workspaces/{ws}/chat`. Member → `/chat` (fullscreen, no sidebar chrome). Set these in your auth callback after login.
06	**Add audit logging middleware** Log every state-changing action to an `audit_events` table: `{event_type, actor_id, actor_role, target_type, target_id, org_id, workspace_id, metadata, timestamp}`. This enables the Audit Log page for Org Admins and Workspace Admins and is a strong selling point for compliance-focused buyers.
07	**Test each role in isolation** Create a test account for each role tier. Verify: (a) the correct nav renders, (b) API calls from unauthorized roles return 403, (c) vector queries never return cross-workspace documents, (d) the Platform Owner impersonation mode is logged in the audit trail. Run this as a regression test on every deployment.

How competitors structure roles (benchmark)

PLATFORM	ROLE TIERS	KEY DESIGN DECISION YOU SHOULD COPY
Confluence	Site Admin → Space Admin → Editor → Contributor → Viewer	Site Admin manages global permissions; Space Admin manages their space independently. Space Admins cannot see other spaces they don't manage. Exactly mirrors your Platform Owner → Org Admin → Workspace Admin model.
Notion Enterprise	Workspace Owner → Membership Admin → Member → Guest	Guests only see the specific pages they're invited to — nothing else. Members see workspace content. Owners manage everything. Their "Membership Admin" tier (manages users but not settings) is a useful middle tier you could add later.

PLATFORM	ROLE TIERS	KEY DESIGN DECISION YOU SHOULD COPY
Guru	Admin → Expert → Viewer	Experts (Editors) can create and edit cards. Viewers can only read and search. Admins manage integrations and team. The key: Viewers land in search, not admin settings. Clean, focused experience per role.
Glean (enterprise search AI)	Super Admin → Admin → User	Super Admin is the platform layer (like your Platform Owner). Admin is per-org (like your Org Admin). Users see only content from sources their SSO identity has access to — permissions are inherited from the source systems (Google Drive, Confluence), not set manually. Worth implementing this in Phase 3.
Hebbia (AI for law/finance)	Admin → Power User → Reader	Power Users can create Projects (like your Workspaces) and upload files. Readers can query Projects they're added to. The "Reader" experience is completely stripped of any management UI — just query and results. Highest priority UX lesson: your Member view should look like this.